Lab 5: Static Code Analysis

Name: Chirra Yuktha Praneel

SRN: PES2UG24AM049

Class: 5th Sem AIML (A)

Program: Ticket Booking System

Date: 22 October 2026

Objective

Analyze the assigned Python program using Pylint, Bandit and Flake8, fix the reported issues, and verify that the booking functions still work.

Actual results

Check	Before	After
Pylint	5.37 / 10	10.00 / 10
Bandit	5 findings: 2 high, 1 medium, 2 low	0 findings
Flake8	7 findings	0 findings
Functional tests	Not run on original	6 tests passed

Program output after fixing

```
Is B1 available: True
Promo price: 16.0
Ticket Hash: 3fab8fc159f6c8f4d993cfca213b143587ff0137b6bbd488716b060a1a33ab80
Booking PIN: 7802
Seating chart exported to: seating_chart.txt
Sold count: 1
```

Verification

Six tests passed: reservations and history, cancellation and availability, valid and invalid discounts, SHA-256 and PIN range, chart export and sold count, and import without demo side effects. The PIN varies between runs. No tool warnings were suppressed.

Submission notes

The package contains the cleaned script, issue table, reflections, all six before/after analyzer reports, test results and a Git bundle with exactly three new commits. Submission repository: github.com/prxneel007/L5_45_ticket_booking_system. The work is organized into three tool-focused commits.

Identified issues and fixes

Line numbers refer to the original assigned script. Manual findings are labeled separately.

Issue / Type	Lines	Description	Fix approach
B324: MD5 hash / High / Security	47	MD5 is a weak hash for security use.	Replace with SHA-256; do not treat a plain hash as authentication.
B605: Shell invocation / High / Security	58	A filename is concatenated into a shell command.	Use print directly; never start a shell.
B307 / W0123: eval / Medium / Security	42	Promo text is executed as Python code.	Accept only base_price * decimal-factor from 0 to 1, validate with a full regex match and calculate directly.
B110 / W0702 / E722: Bare except with pass / Low / Security and Bug	24-27	All errors are silently ignored during cancellation.	Check seat membership explicitly and return False for unknown seats.
B311: Predictable random PIN / Low / Security	51	random is not designed for security-sensitive values.	Use secrets.randbelow, retaining four-digit PINs.
W0102: Mutable default / Bug	15	The same default history list persists between calls.	Default to None and create a fresh list when needed.
C0103: Function naming / Maintainability	15, 71	reserveSeat does not use Python snake_case.	Rename to reserve_seat and update the call.
W1514 / R1732: File resource / Reliability	55-57	File uses implicit encoding and manual closing.	Use a with block and UTF-8 encoding.
W0611 / F401: Unused import / Quality	6	math is never used.	Remove the import.

Identified issues and fixes (continued)

Line numbers refer to the original assigned script. Manual findings are labeled separately.

Issue / Type	Lines	Description	Fix approach
W0612 / F841: Unused variables / Quality	31, 41, 63	booking_fee and seat are unused; eval hides the use of base_price from analysis.	Remove booking_fee, loop over values, and use base_price directly in arithmetic.
C0121 / E711: None comparison / Style	32	None is compared with equality.	Use is None.
R1703 / R1705: Redundant branches / Maintainability	34-37	A condition is converted to True/False through extra branches.	Return the boolean expression directly.
W0621: Shadowed global / Maintainability	61	Parameter hides the global seating map.	Rename parameter to seats.
C0116: Missing docstrings / Documentation	15-69	Functions do not describe their purpose.	Add short function docstrings.
E501 / C0209: Long formatting expression / Style	19	Old string formatting exceeds Flake8's line limit.	Use an f-string and keep final lines within 79 characters.
W292 / C0304: No final newline / Style	82	File does not end in a newline.	Add final newline.
Hard-coded, printed token / Manual security review	70, 79	A secret-like demo string is embedded and displayed. This tool version did not flag it.	Remove the unused token and its print statement.
main runs on import / Manual maintainability review	82	Importing changes seat state and writes a file.	Add an if __name__ == "__main__" guard.

Behavior changes

Promo text accepts only base_price * factor with a decimal factor from 0 to 1. The original base_price * 0.80 example still works. reserveSeat is renamed reserve_seat, and ticket hashes now use SHA-256. Unknown promo seats raise KeyError; invalid expressions raise ValueError. A four-digit PIN and a plain hash are not sufficient production authentication.

Reflection

Note: The supplied README requests four reflection questions, but the supplied four-page handout does not contain their wording. These are four relevant reflection prompts and answers, not quotations from the handout.

1. What did each tool help identify?

Pylint found code quality problems such as the mutable default list, missing docstrings and unused variables. Bandit found security problems such as eval, MD5 and the shell command. Flake8 found formatting and style problems, including long lines and the missing final newline. Some findings overlapped.

2. Which issues were fixed first and why?

The high-severity MD5 and shell-command findings were addressed first, followed by the medium-severity eval finding. SHA-256 replaced MD5, print replaced the shell command, and validated arithmetic replaced eval. The remaining Bandit findings were also fixed. This removed all five reported security findings.

3. How were the fixes verified?

All three tools were run again on the cleaned ticket_booking_system.py. Pylint improved from 5.37 to 10.00, Bandit went from five findings to zero, and Flake8 went from seven findings to zero. Six unit tests checked booking history, cancellation, discounts, hashes and PIN ranges, exports and sold counts, and importing without running the demo. The program was also run successfully.

4. What are the benefits and limitations of static analysis?

Static analysis quickly finds suspicious patterns and helps keep code readable. It does not prove that the program works correctly or is completely secure. For example, the hard-coded token was removed during manual review even though this Bandit run did not report it. Functional tests are still needed. The safe promo format is now intentionally limited, so that change must be documented for callers.

Tools and scope

Python 3.12.14; Pylint 4.1.3; Bandit 1.9.4; Flake8 7.4.1. The submitted analyzer reports target ticket_booking_system.py. Supplementary tests were executed with unittest. Full raw output is included in reports/before and reports/after. The empty final Flake8 report indicates success.